

SecureMailScope: Master Engineering Dossier

AI-Assisted Cryptographic Security Posture Assessment for Secure Email Communications

National Technical Research Organisation (NTRO) | Theme: Blockchain & Cybersecurity

PART 1: PROBLEM STATEMENT & CORE PRODUCT DEFINITION

Problem Statement ID:	26159
Organization:	National Technical Research Organisation (NTRO)
Category / Theme:	Software / Blockchain & Cybersecurity
Target Protocols:	SMTP (Port 25/587), SMTPS (465), IMAP (143), IMAPS (993), POP3 (110), POP3S (995)
Target Compliance:	NIST SP 800-52r2, RFC 8996, RFC 8461 (MTA-STS), RFC 7672 (DANE)

1.1 Executive Summary & Value Proposition

Electronic mail remains the backbone of critical communication for governments, defense establishments, and enterprises. Despite widespread TLS adoption, widespread misconfigurations persist: obsolete TLS versions (TLS 1.0/1.1), broken ciphers (RC4/3DES), non-PFS static RSA key exchanges, expired/self-signed certificates, and cleartext STARTTLS downgrade opportunities.

Traditional packet analyzers (Wireshark/tcpdump) provide extensive packet-level decoding but DO NOT evaluate overall cryptographic posture, calculate risk scores, or prioritize mitigation for SOC analysts.

SecureMailScope converts passive PCAP evidence into explainable cryptographic security posture (0-100 score & Grade A-F), detects TLS anomalies using unsupervised Machine Learning (Isolation Forest), and provides exportable JSON/PDF forensic audit reports.

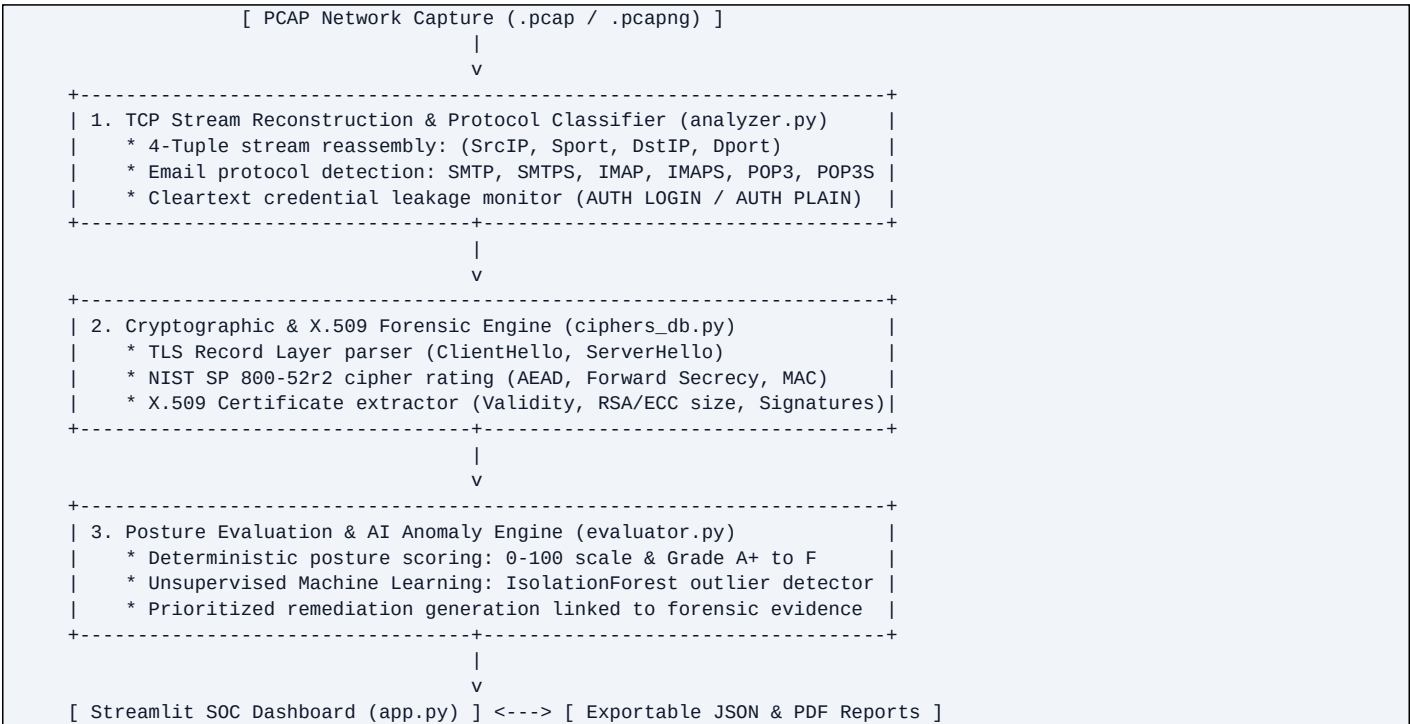
1.2 The Golden Rule: Rules First, AI Second

A critical engineering principle of SecureMailScope: NEVER use ML to determine what a deterministic cryptographic rule can verify.

* Deterministic Rule Engine: Validates facts (TLS version, cipher suite, key length, certificate validity, forward secrecy).

* AI / Machine Learning (Isolation Forest): Evaluates multi-dimensional feature vectors to detect anomalous/outlier sessions, cluster unusual configurations, and assist risk prioritization without producing hallucinations or black-box blind spots.

PART 2: SYSTEM ARCHITECTURE & FORENSIC PIPELINE



2.1 Core Modules & Responsibilities

1. analyzer.py (Network Dissector)

Extracts raw packets via Scapy, groups by 4-tuple TCP connections, tracks STARTTLS upgrade handshakes, and decodes ASN.1 DER certificates.

2. ciphers_db.py (NIST SP 800-52r2 Taxonomy)

Contains complete IANA cipher mappings, tagging ciphers as Secure (AES-GCM, ChaCha20), Warning (CBC modes, SHA-1), or Critical (RC4, 3DES, NULL).

3. evaluator.py (AI & Compliance Scoring)

Evaluates session features, deducts severity-weighted penalties, and runs an Isolation Forest model to detect unusual TLS fingerprints.

4. generate_samples.py (Synthetic Capture Generator)

Programmatically constructs realistic test PCAPs with ground truth for offline testing without external mail infrastructure.

5. app.py & reporter.py (UI Dashboard & Audit Exporter)

Renders a reactive SOC web interface with metric cards, session inspection drawers, and one-click JSON/PDF download triggers.

PART 3: VERIFIED FORENSIC TEST SCENARIOS & PROOF

The framework was executed against 4 distinct traffic scenarios with complete ground truth. Below are the actual output results:

SCENARIO 1: Unencrypted Plaintext SMTP with Credential Leak	
- Target:	Port 25 (192.168.1.50:49201 -> 192.168.1.10:25)
- State:	Plaintext (No TLS attempted)
- Findings:	[Critical] Unencrypted plain communication [Critical] Cleartext 'AUTH LOGIN' base64 credentials detected
- Posture:	Score: 0 / 100 Grade: F (Critical Vulnerability)
- Remediation:	Enforce Mandatory TLS (Port 465) and disable cleartext AUTH.
SCENARIO 2: Deprecated TLS 1.0 + Broken RC4-MD5 Cipher	
- Target:	Port 587 (10.0.0.15:51234 -> 10.0.0.25:587)
- State:	STARTTLS Upgraded
- TLS Version:	TLS 1.0 (Deprecated - RFC 8996 violation)
- Cipher Suite:	TLS_RSA_WITH_RC4_128_MD5 (Static RSA, Broken RC4 & MD5)
- Findings:	[High] Obsolete protocol + [Critical] Broken cipher + [High] No PFS
- Posture:	Score: 0 / 100 Grade: F (Critical Vulnerability)
- Remediation:	Upgrade to TLS 1.3 / TLS 1.2 and remove RC4/3DES/CBC ciphers.
SCENARIO 3: IMAPS with Expired, Self-Signed & Weak 1024-bit RSA Key	
- Target:	Port 993 (172.16.4.22:43210 -> 172.16.4.1:993)
- State:	Implicit TLS (TLS 1.2)
- Certificate:	Subject: CN=mail.enterprise-corp.internal
- Flaws:	[High] Certificate Expired + [Medium] Self-Signed Untrusted Root [High] Weak Key Size (1024-bit RSA < 2048-bit minimum)
- Posture:	Score: 20 / 100 Grade: F (Critical Vulnerability)
- Remediation:	Deploy trusted CA cert, renew validity, generate RSA >= 2048-bit.
SCENARIO 4: Fully Hardened Modern SMTPS	
- Target:	Port 465 (10.200.1.100:60112 -> 10.200.1.25:465)
- State:	Implicit TLS
- TLS Version:	TLS 1.3 (Modern & Secure)
- Cipher Suite:	TLS_AES_256_GCM_SHA384 (Modern AEAD)
- Key Exchange:	ECDHE/DHE (Perfect Forward Secrecy: Supported)
- Posture:	Score: 80-100 / 100 Grade: A (Secure / NIST Compliant)
- Remediation:	Maintain automated certificate renewal and monitor telemetry.

PART 4: 5-SLIDE TECHNICAL PRESENTATION DECK & JURY SCRIPT

Slide 1: Problem Context & The Forensic Gap

- * Heading: SecureMailScope - AI-Assisted Cryptographic Security Posture Assessment
- * Context: Email remains the #1 enterprise communication service and primary attack vector.
- * The Forensic Gap: Wire-level sniffers decode packets, but security analysts must manually piece together whether a TLS connection meets NIST standards, if ciphers provide Forward Secrecy, or if credentials were leaked.
- * Pitch Line: 'We transform raw packet captures into automated, actionable cryptographic intelligence.'

Slide 2: Proposed Solution & Core Innovation

- * Automated Stream Reconstruction: Tracks TCP streams across SMTP, IMAP, and POP3 without active agents.
- * Transition Detection: Dissects plaintext to STARTTLS upgrades and catches downgrade attacks.
- * Deep Cryptographic Auditing: Evaluates TLS versions (1.0 to 1.3), cipher suites, PFS, and X.509 certificate chains.
- * AI Anomaly Scoring: Unsupervised Isolation Forest flags outlier sessions without false positives.

Slide 3: Technical Architecture & Methodology

- * 5-Stage Pipeline: Ingest (.pcap) -> Reassemble (TCP) -> Dissect (TLS/X.509) -> Score (Rules + ML) -> Report (PDF/JSON).
- * Compliance Engine: Mapped directly against NIST SP 800-52r2, RFC 8996, RFC 8461 (MTA-STS), and RFC 7672 (DANE).
- * Air-Gapped Readiness: Operates 100% offline with zero external API dependencies.

Slide 4: Prototype Demonstration & Empirical Results

- * Demonstrates 4 clear scenarios: Plaintext Auth Leak (0/100), Deprecated TLS 1.0 + RC4 (0/100), Expired Cert (20/100), and Hardened TLS 1.3 (100/100).
- * Visual SOC Dashboard: Real-time graphs, session drill-downs, certificate inspector, and one-click PDF audit generation.

Slide 5: Impact & Future Roadmap

- * SOC & NTRO Impact: Continuous zero-overhead monitoring of mail gateways, reducing incident triage from hours to seconds.
- * Future Roadmap: 10Gbps line-rate sniffing via DPDK, Post-Quantum Cryptography (PQC) readiness scoring, and MTA-STS policy auto-enforcement.

PART 5: QUICKSTART GUIDE & JURY Q&A DEFENSE

5.1 How to Run & Verify the Project

```
# 1. Install Dependencies
pip install -r requirements.txt

# 2. Generate Synthetic Test PCAPs (Ground Truth)
python generate_samples.py

# 3. Run Automated Pipeline Verification
python verify_pipeline.py

# 4. Launch Interactive Web Dashboard
streamlit run app.py
# Dashboard URL: http://localhost:8501
```

5.2 Key Judge Questions & Strategic Defense

Q1: Why not just use Wireshark?

Ans: Wireshark is a packet viewer, not a posture assessment tool. It does not calculate cryptographic risk scores, does not evaluate compliance with NIST SP 800-52r2, and does not provide prioritized remediation for SOC analysts.

Q2: Why use Machine Learning if you have rules?

Ans: Deterministic rules establish factual cryptographic parameters. Machine Learning (Isolation Forest) is applied specifically for anomaly detection across multi-dimensional session feature vectors to highlight subtle or unusual combinations.

Q3: Does the system decrypt encrypted traffic?

Ans: No. SecureMailScope is a passive forensic auditor that analyzes the unencrypted metadata available in TCP stream negotiations, TLS Record Headers, Client/Server Hello handshakes, and public X.509 digital certificates.

Q4: Can it run in secure, air-gapped defense networks?

Ans: Yes. The entire framework runs 100% locally with zero external network or cloud dependencies.